

Authentication + JavaScript Interview Cheat Sheet

Authentication Types

Password-Based: Traditional username/password.

Token-Based: Stateless JWTs for APIs.

Session-Based: Server stores session ID.

OAuth2: Third-party delegated auth.

OpenID Connect: OAuth2 + user identity.

MFA: Combines factors (e.g., password + TOTP).

Biometric: Face ID, fingerprint.

Certificate-Based: Mutual TLS auth.

Storing Tokens

httpOnly Cookies:

- Set on server with `res.cookie()`
- Cannot be accessed via JS (XSS-safe)
- Automatically sent with each request.

In-Memory:

- Stored in JS variable/state
- Lost on refresh
- Safer than `localStorage` if app is XSS-free.

Persist Tokens Across Refresh (SPA)

Best Practice:

- Store access token in memory.
- Store refresh token in httpOnly cookie.

On login:

- Server sets httpOnly cookie for refresh token.
- Returns access token to frontend.

On page load:

- Call `/refresh-token` using `fetch` with credentials.
- Server validates cookie, returns new access token.

Token Rotation, Binding & Invalidation

Rotation:

- Use short-lived access + long-lived refresh tokens.
- Invalidate old refresh tokens on use.

Binding:

- Attach device ID, IP to token payload.

Blacklisting:

- Store invalidated token `jti` in Redis/DB.
- Check blacklist before accepting token.

Authentication + JavaScript Interview Cheat Sheet

JavaScript: Promises vs Callbacks

Promise:

- Represents async result (fulfilled/rejected)
- .then(), .catch(), .finally()

Callback:

- Function passed to another function
- Manual chaining & error handling

Promises improve readability and chaining.

Understanding 'this' in JavaScript

'this' refers to the context of execution:

- Global: window (browser)
- Object method: the object itself
- Arrow function: lexical scope
- Constructor: instance created by function.

Best Practices

- Use HTTPS always
- Short-lived access tokens
- Store refresh tokens in httpOnly cookies
- Rate limit login attempts
- Use secure headers (CSP, HSTS, SameSite)
- Implement MFA for sensitive actions